

Final Project: SecureHealth Inc. Data Management System

Estimated time needed: 30 minutes



Introduction

SecureHealth Inc. is a medium-sized healthcare provider that manages patient records, medical histories, and insurance information for thousands of patients across multiple locations. Over the past few years, SecureHealth has experienced significant growth, driven by its expansion into new regions and increased patient volume.

Given the complexities of modern data management, SecureHealth requires the expertise of a Data Manager to lead the development and implementation of a secure, compliant, and efficient data system. The role of the Data Manager will be critical in addressing the company's current challenges and laying the foundation for future growth.

Key Responsibilities of the Data Manager:

1. **Ensure Data Privacy and Security:** Oversee the implementation of data encryption, RBAC, and other security measures. Work with IT and security teams to prevent data breaches and unauthorized access to sensitive information.
2. **Drive Compliance with Regulations:** Lead efforts to align the data management system with HIPAA and GDPR requirements. Implement tools and processes that ensure auditability, data retention, and patient control over their data.
3. **Redesign Data Architecture:** Rebuild the existing data architecture to support scalability, data integrity, and performance. Optimize data storage, retrieval, and processing to meet the demands of a growing healthcare provider.
4. **Implement Governance and Risk Management:** Develop and enforce data governance policies that ensure data quality, ownership, and security. Identify and mitigate data risks, ensuring that SecureHealth is prepared for potential cybersecurity threats and system failures.
5. **Facilitate Data-Driven Decision Making:** Help the organization leverage its data for analytics and insights, improving patient care and operational efficiency.

Objectives

At the end of the project, you will be able to:

1. Implement **data privacy** and **encryption** mechanisms in a relational database.
2. Design a scalable **data architecture** and develop **data governance policies**.
3. Apply principles of **data risk management** and **compliance** with regulations like GDPR and HIPAA.
4. Apply **role-based access control (RBAC)** to ensure secure access to data.

5. Implement **audit trails** and **compliance reporting** to track and manage sensitive data.

The project is divided into three parts, which are to be submitted sequentially:

1. **Part 1:** Implementing Data Privacy, Security, Encryption, and Role-Based Access using MySQL.
2. **Part 2:** Applying concepts of Data Architecture, Data Management, and Governance.
3. **Part 3:** Applying concepts of Data Risk Management, Compliance, and Regulatory Standards.

Part 1: Implementing Data Privacy, Security, Encryption, and Role-Based Access using MySQL

Objective:

Design and implement a **secure MySQL database** for SecureHealth Inc. to store sensitive patient and employee data. Learners will apply **data privacy** measures such as **encryption** and implement **role-based access control** to protect this sensitive information.

Instructions

Prior to the project tasks, perform the following tasks to create tables and enter sample data using SQL:

1. **Create the database:**

- Set up a MySQL database named SecureHealthDB to store **patients' medical records** and **employee details**.

2. **Create the necessary tables:**

- **Patient Table:** Stores sensitive data like patient name, DOB, medical history, and insurance information.
- **Employee Table:** Stores employee names, roles, and encrypted passwords.
- **Roles Table:** Defines roles such as **Doctor**, **Nurse**, and **Admin** to control access.

Creating database and tables

Implement the following code:

```
sql
-- Step 1: Create the SecureHealth Database
CREATE DATABASE SecureHealthDB;
-- Step 2: Use the Database
USE SecureHealthDB;
-- Step 3: Create a Table for Employees
CREATE TABLE employees (
  id INT AUTO_INCREMENT PRIMARY KEY,
  name VARCHAR(100) NOT NULL,
  role_id INT, -- Links to roles table for role-based access
  email VARCHAR(100) NOT NULL,
  password VARBINARY(255) -- Encrypted password for secure login
);
-- Step 4: Create a Table for Patient Information (Sensitive Data)
CREATE TABLE patients (
  id INT AUTO_INCREMENT PRIMARY KEY,
  name VARCHAR(100) NOT NULL,
  dob DATE, -- Date of Birth
```

```
medical_record VARBINARY(255), -- Encrypted field for medical history
insurance_number VARBINARY(255) -- Encrypted field for insurance details
);
-- Step 5: Create a Roles Table for Role-Based Access Control
CREATE TABLE roles (
  id INT AUTO_INCREMENT PRIMARY KEY,
  role_name VARCHAR(50) NOT NULL
);
-- Step 6: Create a Table to Assign Roles to Employees
CREATE TABLE employee_roles (
  employee_id INT,
  role_id INT,
  FOREIGN KEY (employee_id) REFERENCES employees(id),
  FOREIGN KEY (role_id) REFERENCES roles(id)
);
```

Tasks

Perform the following tasks:

Task 1: Insert sample data into the Roles Table as Doctor, Nurse, and Admin. Upload the screenshot of the code as **Part1_Task1.png**.

Task 2: Implement data encryption using AES encryption for sensitive fields and verify encrypted data in the patients table. Upload the screenshot of the code as **Part1_Task2.png**.

Task 3: Insert employees and assign roles in employees and employees_roles tables. Upload the screenshot of the code as **Part1_Task3.png**.

Task 4: Implement Role-Based Access Control (RBAC) by creating a user for each role. Upload the screenshot of the code as **Part1_Task4.png**.

Task 5: Test and validate the access control as per the scenarios. Upload a PDF named **Part1_Task5** that includes the following screenshots of the code:

- Scenario 1: Doctor's Access (**Part1_Task5a.png**)
- Scenario 2: Nurse's Access (**Part1_Task5b.png**)
- Scenario 3: Admin's Access (**Part1_Task5c.png**)

Solution Exemplar:

- **Patient Table:** Stores encrypted fields for medical records and insurance numbers.
- **Employee Table:** Ensures role-based access by using MySQL users and passwords.
- **Test Cases:** Query results show that doctors can decrypt sensitive data, while nurses only see non-sensitive fields.

Part 2: Applying concepts of Data Architecture, Data Management, and Governance

Objective:

Design the **data architecture** for SecureHealth Inc. and develop a **data management** plan with a **governance framework** to ensure data quality, security, and scalability.

Instructions:

Perform the following tasks:

Task 1: Design the data architecture:

- Create an Entity-Relationship Diagram (ERD) that represents the relationships between patients, employees, and their roles.
- Ensure that the data is normalized to avoid redundancy and ensure efficient queries.

Upload the screenshot of the ERD diagram as **Part2_Task1.png**.

Task 2: Create a governance policy that covers:

- Data governance core principles. Upload a Word file named **Part2_task2a.doc**.
- Roles and responsibilities. Upload a Word file named **Part2_task2b.doc**.

Solution Exemplar:

- ER Diagram:** Displays the relationships between patients, employees, and roles. Architecture follows the rules of normalization to prevent redundancy.
- Governance Framework:** A well-defined policy that includes data ownership, rules for data access control, rules for maintaining data accuracy and completeness, and mechanisms for tracking data access and changes.

Part 3: Applying concepts of Data Risk Management, Compliance, and Regulatory Standards.

Objective:

Implement data risk management strategies and ensure compliance with regulations like GDPR and HIPAA. This part will focus on managing data risk and ensuring regulatory compliance by incorporating secure data storage, audits, and logging.

Instructions:

Perform the following tasks:

Task 1: Create a data risk management document with a comprehensive list of risks and their corresponding mitigation strategies, such as encrypting sensitive data, backing up the database, and multifactor authentication. Upload a Word file named **Part3_task1.doc**.

Task2: Create a compliance document with GDPR and HIPAA regulations with access control, audit logs, and data retention policies. Upload a Word file named **Part3_task2.doc**.

Task 3: Enable MySQL's general query log to track access to sensitive information and implement triggers to log changes made to sensitive fields like patient records. Upload a screenshot of code **Part3_task3.png**.

Solution Exemplar:

- **Risk Management Plan:** A comprehensive list of risks and their corresponding mitigation strategies, such as encrypting sensitive data and backing up the database.
- **Compliance Implementation:** The database follows GDPR/HIPAA regulations with access control, audit logs, and data retention policies.
- **Audit Logs:** Demonstrates logging and monitoring of all changes made to critical tables.

Final Deliverables

Learners will submit the following:

1. MySQL scripts as screen shots for implementing database tables, encryption, and role-based access.
2. Data architecture in an Entity Relationship diagram as a screen shot. Response for governance framework as a Word document.
3. Word document as a response for Risk Management Plan and compliance documentation. Screen shot of MySQL script for audit logs.

Conclusion

Congratulations! At the completion of the project, you have learned to implement data privacy and encryption mechanisms in a relational database. You have designed a scalable data architecture and developed an ERD diagram. You have created a governance policy and applied principles of data risk management and compliance with regulations like GDPR and HIPAA. You have applied role-based access control (RBAC) to ensure secure access to data and implemented audit trails and compliance reporting to track and manage sensitive data.

Author(s)

Parikshit Jain